

WHITE PLAINS HOSPITAL — INCIDENT RESPONSE PLAN ADDITIONS

ADDITIONS TO WPH-IRP-2026-001 | Missing Playbooks + Templates | Version 1.1 | April 2026

This document contains additions to the White Plains Hospital Cybersecurity Incident Response Plan (WPH-IRP-2026-001 v1.0). It should be read alongside and incorporated into the main IRP. These additions complete the missing Scenario C (Phishing) and Scenario D (Insider Threat) playbooks referenced in the IRP cover table, plus mandatory templates for after-action reporting and patient breach notification.

DOCUMENT CONTROL: Upon adoption, update the main IRP version to 1.1 and incorporate these sections as Sections 7.3, 7.4, and Appendices A and B.

7.3 Phishing — Credential Theft Playbook

Phishing is the leading initial access vector in healthcare cyberattacks. When an employee reports clicking a suspicious link or a credential compromise is suspected, every minute counts. This playbook covers the specific response steps for phishing incidents that may result in unauthorized EHR access. Cross-reference: Risk Register WPH-R01.

⚠ CRITICAL: Do NOT let the compromised employee attempt to self-remediate or change their own password before IT Security captures forensic evidence. The order of steps below is deliberate.

STEP 1 — DETECT & REPORT

#	Action	Details	Owner
1	Employee reports suspicious email	Employee calls IT helpdesk at Ext. 5555. Do NOT email the report — email may be compromised. Collect: sender address, subject line, link clicked, time, and any credentials entered.	Employee → IT Helpdesk
2	Log initial report	GRC Analyst creates incident ticket WPH-INC-[YEAR]-[#]. Record exact time, employee name, role, and system accessed after clicking.	GRC Analyst
3	Preserve evidence — DO NOT TOUCH THE DEVICE	Instruct employee to step away from workstation. IT Security takes control. Screenshot phishing email if visible. Do NOT delete the email.	IT Security
4	Classify severity	P2 = credential entered or EHR accessed. P3 = link clicked, no credentials entered. Escalate to P1 if multiple accounts compromised or active EHR access ongoing.	IT Security + GRC

STEP 2 — CONTAIN

#	Action	Details	Owner
1	Revoke compromised credentials immediately	Disable the affected user account in Active Directory. Force sign-out of all active sessions including Epic EHR, email, VPN, and all cloud systems. Complete within 15 minutes of P2 declaration.	IT Security
2	Identify phishing email source	Pull email headers. Identify sending IP and domain. Block sender domain at email gateway. Check if same email was delivered to other staff — block and quarantine organization-wide.	IT Security
3	Block malicious URLs	Identify URLs in the phishing email. Block at web proxy and DNS level. Check web proxy logs for other users who may have clicked the same link.	IT Security
4	Assess EHR access during compromise window	Pull Epic EHR audit logs for the affected user account from time of phishing click to account disable. Identify every patient record accessed. Privacy Officer reviews for HIPAA breach assessment.	Privacy Officer + IT
5	Notify Incident Commander	If any PHI was accessed during compromise window — escalate to P1 and notify CISO immediately. Begin HIPAA breach assessment timeline.	GRC Analyst

STEP 3 — INVESTIGATE

#	Action	Details	Owner
1	Forensic capture	Create forensic image of affected workstation before any remediation. Preserve browser cache, credential manager, downloaded files.	IT Security

2	Lateral movement check	Check network logs for any connections from compromised account to other systems, file shares, admin panels during compromise window.	IT Security
3	Phishing kit analysis	Identify phishing kit type (credential harvester, malware dropper, etc.). Determine if malware was installed. Run full AV/EDR scan of affected device.	IT Security
4	Check for persistence mechanisms	Look for new scheduled tasks, registry run keys, new user accounts, or unusual startup items created during compromise window.	IT Security

STEP 4 — NOTIFY & REMEDIATE

#	Action	Details	Owner
1	Privacy Officer breach assessment	If patient records were accessed: apply HIPAA four-exception test. Determine if notification is required. Begin 60-day clock from discovery date.	Privacy Officer
2	Credential reset — controlled	IT Security resets compromised account password. Enable MFA before re-activating account. Verify employee identity before returning access.	IT Security
3	Organization-wide alert	HR sends staff alert: 'We have identified a phishing campaign targeting WPH email accounts. Do not click links from [sender domain]. Report suspicious emails to Ext. 5555 immediately.' No details of the specific incident.	HR / Comms Lead
4	Mandatory phishing awareness session	Affected employee completes 1:1 phishing awareness session with GRC Analyst before return to EHR access. Document session completion.	GRC Analyst

NOTE: If the phishing resulted in malware installation, transition to the Ransomware Playbook (Section 7.1) immediately.

7.4 Insider Threat Playbook

Insider threats require a fundamentally different response approach than external attacks. Legal, HR, and Privacy must be involved BEFORE IT takes visible action — because premature account action can tip off the subject, destroy evidence, and create wrongful termination liability. Cross-reference: Risk Register WPH-R04.

⚠ CRITICAL SEQUENCE RULE: Legal Counsel and HR must be notified BEFORE any account action is taken against the suspected individual. Violating this sequence exposes WPH to legal liability. Follow steps in exact order.

INSIDER THREAT CATEGORIES

Type	Description	Initial Indicator
Curiosity / Snooping	Employee accesses records of celebrities, neighbors, or coworkers without clinical justification	Audit log anomaly: patient records accessed outside employee's patient care area or without clinical encounter
Data Exfiltration	Employee downloading, printing, or emailing bulk patient records, possibly before resignation	Unusual volume of print jobs, bulk exports, large email attachments, or USB activity
Account Abuse	Employee sharing credentials, accessing system under another identity, or using admin access beyond job scope	Login from unusual location, after-hours access, access from two locations simultaneously
Malicious Breach	Deliberate breach with intent to sell or damage PHI — highest severity	Contact from law enforcement, patient complaint about privacy, media inquiry, unusual external account activity

STEP 1 — DETECT & ASSESS (SILENTLY)

#	Action	Details	Owner
1	Identify the indicator	Epic EHR audit anomaly, employee report, patient complaint, or HR tip. Document exact source, time, and nature of suspicion. Do NOT act yet.	Privacy Officer / GRC
2	Silent preliminary review	Privacy Officer reviews audit logs SILENTLY — no account changes, no alerts, no contact with the subject. Determine scope: which records, how many patients, time period.	Privacy Officer
3	Assess severity	P1 = active ongoing access or bulk exfiltration in progress. P2 = historical access without clinical justification. Classify before notifying IRT.	Privacy Officer + GRC
4	Preserve all evidence before any notification	IT Security creates forensic-quality export of all audit logs related to the subject. Lock logs to prevent deletion. This must happen BEFORE any action that could alert the subject.	IT Security

STEP 2 — ESCALATE (LEGAL FIRST)

#	Action	Details	Owner
1	Notify General Counsel first	Legal Counsel briefed before any HR or IT action. Legal advises on employment law implications, litigation hold requirements, and law enforcement notification.	CISO → Legal Counsel
2	Notify HR	HR Director briefed. HR advises on employment status of subject — active, on notice, performance plan. HR coordinates response with Legal.	Legal → HR Director
3	Notify CISO and activate IRT	Incident Commander activated. Full IRT assembled. Communications strictly limited to IRT members — no discussion outside secure channel.	CISO

4	Litigation hold	Legal places litigation hold on all evidence. IT preserves all related emails, files, and logs. No routine deletion or overwrite permitted.	General Counsel + IT
---	-----------------	---	----------------------

STEP 3 — CONTAIN & INVESTIGATE

#	Action	Details	Owner
1	Timed account suspension	Legal and HR authorize account suspension. Timing coordinated with HR meeting or termination action. Do NOT suspend account before HR is ready to act — this tips off the subject.	IT Security (on Legal/HR signal)
2	Full forensic investigation	IT Security conducts full forensic analysis: workstation, email, network logs, print logs, USB activity, cloud storage access. Preserve complete chain of custody.	IT Security
3	Quantify PHI exposure	Privacy Officer identifies every patient record accessed without justification. Determine: record count, data types (diagnosis, SSN, financial, etc.), time period, and whether data was exfiltrated.	Privacy Officer
4	Law enforcement decision	Legal Counsel evaluates whether law enforcement notification (FBI, HHS-OIG) is required or advisable. Document the decision and rationale regardless of outcome.	General Counsel

STEP 4 — NOTIFY & RECOVER

#	Action	Details	Owner
1	HIPAA breach assessment	Privacy Officer applies four-exception test. If PHI was improperly accessed or disclosed: begin 60-day notification clock. Notify patients and HHS per breach notification requirements (Section 5).	Privacy Officer
2	HR disciplinary action	HR executes disciplinary action per the WPH Sanction Policy. Outcome documented in personnel file. GRC Analyst documents in incident record.	HR Director
3	Access review — role review	Conduct full user access review for the subject's department. Verify no other accounts have inappropriate access to the same patient population.	IT Security + Privacy
4	Control enhancement	Implement additional audit alert rules for the affected access pattern. Increase monitoring intensity on the subject's department for 90 days post-closure.	IT Security + GRC

DOCUMENTATION REQUIREMENT: *Insider threat incidents must be documented with exceptional care — every step, every decision, every communication — as these cases frequently result in legal proceedings. GRC Analyst maintains a separate, access-controlled incident record for insider threat cases.*

APPENDIX A — After-Action Report Template

Complete this report within 14 days of incident closure. GRC Analyst owns completion. CISO reviews and approves. File in incident record and retain for 6 years.

INCIDENT IDENTIFICATION	
Incident ID	WPH-INC-[YEAR]-[#]
Incident Type	☐ Ransomware ☐ Data Breach ☐ Phishing/Credential Theft ☐ Insider Threat ☐ Other: _____
Severity Classification	☐ P1 Critical ☐ P2 High ☐ P3 Medium ☐ P4 Low
Date Discovered	_____ Time: _____
Date Contained	_____ Time: _____
Date Closed	_____ Time: _____
Total Incident Duration	_____ hours/days from discovery to closure
PHI Involved	☐ Yes — ____ patients affected ☐ No ☐ Under investigation
HIPAA Breach?	☐ Reportable breach ☐ Not reportable (exception applies — document below) ☐ Investigation pending

ROOT CAUSE ANALYSIS
What was the confirmed root cause of the incident? (Initial access vector, vulnerability exploited, process failure)

What controls failed or were absent that allowed this to occur?

IRT PERFORMANCE REVIEW	Rating (1–5)	Notes
Detection speed		
Containment speed		
Communication effectiveness		
HIPAA notification compliance		
Recovery speed		
Documentation quality		

CORRECTIVE ACTIONS REQUIRED			
Action Required	Owner	Priority	Due Date
Update IRP based on lessons learned	GRC Analyst	High	30 days

SIGN-OFF	Name	Signature	Date
Prepared By (GRC Analyst)			
Reviewed By (CISO)			
Legal Counsel Cleared			

APPENDIX B — Patient Breach Notification Letter Template

HIPAA Breach Notification Rule (45 CFR §164.400–414) requires written notification to affected patients within 60 days of breach discovery. This template meets all required content elements. Legal Counsel must review and approve before sending.

Send via: First class mail to last known address OR email if patient has authorized electronic communication. For 500+ patients in one state: also notify prominent media outlets and submit HHS breach report.

[DATE]

[Patient Name]

[Patient Address Line 1]

[City, State, ZIP]

Re: Notice of Security Incident Affecting Your Health Information

Dear [Patient Name],

We are writing to inform you of a security incident that may have involved your protected health information. White Plains Hospital takes the privacy and security of your personal and health information very seriously, and we are committed to being transparent about this matter.

WHAT HAPPENED

On [DATE OF DISCOVERY], White Plains Hospital discovered that [brief description of incident — e.g., an unauthorized individual accessed our electronic health record system]. The incident occurred between [START DATE] and [END DATE].

WHAT INFORMATION WAS INVOLVED

The following types of your information may have been accessed: [LIST APPLICABLE ITEMS]

- Name and date of birth
- Medical record number
- Diagnosis and treatment information
- Health insurance information
- [Add or remove items based on actual breach scope]
- Social Security Number: ☐ Yes ☐ No
- Financial account information: ☐ Yes ☐ No

WHAT WE ARE DOING

Upon discovering this incident, we immediately took the following steps to secure your information and prevent further unauthorized access: [DESCRIBE ACTIONS TAKEN — e.g., disabled compromised accounts, enhanced security monitoring, deployed additional access controls, conducted forensic investigation]. We have also implemented [ADDITIONAL SECURITY MEASURES] to help prevent a similar incident from occurring in the future.

WHAT YOU CAN DO

We recommend you take the following steps to protect yourself:

- Review your Explanation of Benefits (EOB) statements from your health insurer for any unfamiliar services
- Monitor your medical records for any care you did not receive
- If your Social Security Number was involved: Place a fraud alert or credit freeze with the three major credit bureaus (Equifax, Experian, TransUnion) and review your credit reports at www.annualcreditreport.com
- Be alert for phishing emails or phone calls claiming to be from White Plains Hospital

[IF SSN INVOLVED — ADD THIS PARAGRAPH]

We are providing you with [X] months of complimentary credit monitoring and identity protection services through [VENDOR NAME]. Instructions for enrollment are enclosed. Please enroll by [ENROLLMENT DEADLINE DATE].

FOR MORE INFORMATION

If you have questions about this notice or would like more information about what occurred, please contact our Privacy Officer:

White Plains Hospital — Privacy Officer

Phone: [PHONE NUMBER] (Monday–Friday, 9 AM–5 PM Eastern)

Email: privacy@whiteplainshospital.org

Mail: [ADDRESS]

You may also file a complaint with the U.S. Department of Health and Human Services, Office for Civil Rights at www.hhs.gov/ocr/privacy/hipaa/complaints/ or by calling 1-800-368-1019.

We sincerely regret any concern or inconvenience this incident may cause you. Protecting your health information is a responsibility we take with the utmost seriousness.

Sincerely,

[CISO Name], Chief Information Security Officer

White Plains Hospital